

Performing a taxonomy-informed semantic reconciliation of the W3C Data Privacy Vocabulary to surface implementation considerations, decision points, and issues.

Brice Dobson, Georgia Institute of Technology, Atlanta, GA, USA

Abstract

Large organizations with multi-jurisdictional privacy obligations manage significant volumes of privacy-relevant information across many process subdomains. Frequently, these organizations look to external frameworks, taxonomies, or ontologies to inform the design of these process subdomains. These frameworks often feature high internal validity but have low semantic compatibility with what is around them. Further, there is no overarching data model focused on harmonizing the work occurring within one subdomain with related concepts in adjacent subdomains, despite their data entities being inherently related in principle and practice. The result is that large organizations are left to draw compliance conclusions from data that is insufficiently precise, normalized, or complete for the purpose, ultimately representing not only a compliance risk but a maturity ceiling in the face of a bona fide desire to comply.

This work considers what a truly unified data model for privacy would look like for a large organization if the interoperability across its constituent process domains (subdomains) were forced. Using a canonical ontology as a foundation, the W3C Data Privacy Vocabulary, a reference data model was constructed that forced this interoperability and expanded on the DPV by an order of magnitude. The work of constructing this reference model highlighted entities and relationships that are invariant multi-jurisdictionally and represent fundamental flaws of understanding and compatibility when modified, a methodology to support maturity keying and explicit consideration of the data model rework points associated with improving process maturity over time, over 40 opportunities to make latent decisions explicit to better align risk appetite and tolerance within the implementing organization, and an approach for extension of regulation-specific entities and relationships.

Keywords: Data Privacy, Privacy Operations, Privacy Taxonomy, Privacy Ontology, Privacy Data Model, Data Privacy Vocabulary, W3C DPV, CMMI

CONTENTS

1	Introduction	2	
2	Background	2	
2.1	The evolving regulatory environment	2	
2.2	Independent standards bodies	3	
2.3	Large organizations	3	
2.4	Commercial privacy tools	3	
2.5	Ontologies, taxonomies, and schemas, oh my!	3	
2.6	Where the DPV stops	4	
2.7	Maturity, regulation, and risk	4	
3	Methodology	5	
3.1	Characterizing the DPV and identifying subdomains	5	
3.2	Identifying authoritative sources per subdomain	5	
3.3	Extracting the structure each source implies	6	
3.4	Normalizing within each subdomain	6	
3.5	Cross-subdomain joining	7	
3.6	Evaluation	7	
4	A Reference Data Model for Organizational Privacy Management	8	
4.1	Data model shape and positioning	8	
4.2	The regulation-agnostic spine	9	
4.3	Normalization and Reification	10	
4.4	Things without a clear home	10	
4.5	Connecting subdomains	10	
4.6	Accounting for regulation	10	
4.7	Accounting for growth and maturity increase	11	
4.8	Accounting for and expressing risk tolerance	12	
4.9	What the model looks like in each program area	12	
4.10	Defining DPV <-> reference model handoffs, DPV gaps	13	
4.11	The delivered artifacts	14	
5	Limitations, Qualifications, and Future Work	14	
5.1	Limitations	14	
5.2	Qualifications	14	
5.3	Future Work	15	
6	Conclusions	15	
7	Appendices	17	
8	References	23	

1. INTRODUCTION

Organizations, especially larger ones with multi-jurisdictional privacy compliance imperatives, implicitly manage many seemingly disparate categories of privacy-relevant information. These include inventories and data flows, processes and activities, purposes and lawful bases, notices, consent records, invocations of individual rights information, and formal assessments of compliance, harms, and risks. If we consider privacy an overarching process domain within an organization, each of these manifests as subdomains. Each subdomain has between several and many external frameworks and taxonomies available for reference and implementation. These are inherently grounded in regulatory expectations, representing reasonable approaches for an organization to structure their processes and data within that subdomain. While they may be internally valid within their respective subdomains, organizations quickly experience interoperability problems in a messy middle where semantic incompatibilities arise, causing a myriad of potential issues for the implementing organization, especially as it grows and matures its process design and execution.

The difficulties that arise from managing privacy-relevant data coherently are not attributable to any single actor but rather at the convergence of four.

1. Governments that legislate and enforce regulation.
2. Standards bodies that seek to further interpret, operationalize, and standardize requirements.
3. Large organizations that seek to advance their missions and comply with law and regulation in the process.
4. Commercial tool and service providers who seek to capitalize on the opportunities created by these conditions.

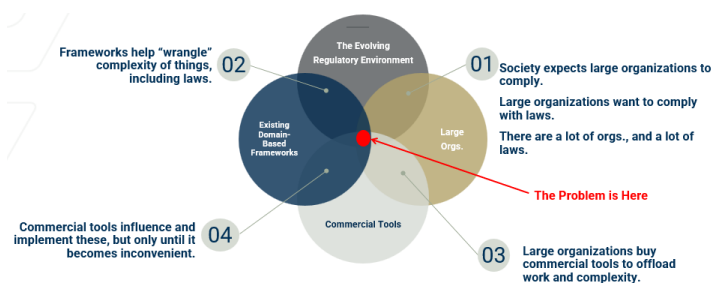


Figure 1. Illustration of convergence problem and positioning.

Regulations typically stop short of codifying the full relationships of the concepts they govern. Independent standards are scoped and published at inconsistent levels of analysis and often with limited consideration for interoperability. Large organizations operationalize under internal resource and knowledge constraints, and commercial tools implement solutions that implicitly and sometimes unknowingly resolve decision points that proxy for risk tolerance, often favoring their own convenience.

Disconnected taxonomies and data models produce inconsistent terminology and data, this results in duplication without clear authority and unrecognized or unclear relationships. Organizations rely on the resulting data to draw conclusions in contexts where that data is not sufficiently precise, normalized,

or complete for the purpose. This creates a vulnerable condition for operational and legal compliance failure modes such as exceeding purpose specification in ways that erode lawful bases, inadequate recognition and fulfillment of individual rights, and missed opportunity through poor application of legal requirements. I approach this in a data-first manner with the assertion that there is a level of data normalization where these linked-but-incompatible process subdomains become compatible, and that in a well-run privacy program, drift from that normalized form should be a deliberate function of maturity targets and formally accepted risk, not an accident of tooling or organizational structure.

This paper represents the question *What would a truly unified data model for privacy look like for a large organization if interoperability across its constituent process domains were forced?*

This problem cannot be solved through a fixed schema because the structure inherently varies with the organization's target and actual process maturity, its portfolio of regulatory mandates, and its risk tolerance. The solution must instead be a parameterized structure with robust consideration for extension, typing, and the implicit decisions arising from accounting of entities and relationships that are inherently expressions of risk tolerance. In short, a reference data model.

This work manifests in four artifacts.

1. A reference data model spanning 12 privacy capability subdomains, comprising 34 core entities, 65 core relationships, and 12 reified-association classes, connected by 87 cross-subdomain joins and layered for regulation, maturity, and risk.
2. An enumeration of 40 latent decision points that organizations are currently resolving implicitly, often without recognizing that they are accepting risk in doing so.
3. The identification of 13 gaps in a canonical ontology that was adopted as a foundation of this work, of which 10 are substantively improved upon here.
4. A machine-readable serialization of the model together with an interactive web-based explorer, evaluated through 100 SPARQL-validated test cases over 12 refinement iterations.

The remainder of this paper proceeds as: Section 2 establishes the regulatory, organizational, and standards conditions that motivate the work. Section 3 describes the phased methodology by which the model was derived and evaluated. Section 4 presents the reference model itself, including its analytic underpinnings. Section 5 states limitations, qualifications, and future work, and Section 6 concludes.

2. BACKGROUND

This section contextualizes the problem space and provides foundational knowledge for this work, examining each of the four actors before characterizing the ontological starting point.

2.1. The evolving regulatory environment

At least 144 countries now have laws addressing privacy and data protection obligations of organizations [1]. These take similar but

not perfectly compatible approaches, split between comprehensive and sectoral models, and regulators are often unconcerned if the law they enforce creates a compliance issue under another regulatory regime. Simultaneously, individuals are becoming more aware of their rights as data subjects, with industry reporting a 128% increase in individual rights request rates per million identities in just a two-year period [2]. Enforcement is widening in parallel, with the early actions grounded in data security issues and breaches giving way to lawful basis and individual rights issues, which now represent one-third and one-quarter of known GDPR enforcement actions, respectively [3].

2.2. Independent standards bodies

Independent standards bodies occupy the space between the regulators who define required outcomes and the organizations expected to produce them. Institutions such as ISO/IEC, IEEE, and the W3C convert broad legal duties into defined recommended practices through consensus processes, member review, and published revision cycles. This deliberateness of authorship is what establishes their credibility, which translates to authority over time. While the authority of these bodies is persuasive rather than coercive, regulators lean on standards to give operational meaning to ambiguous legal requirements, with the GDPR's "state of the art" security obligation being a canonical example [4], because referencing an evolving standard spares the law from codifying technical detail it could not keep current.

While adoption of any independent standard is typically voluntary and does not convey or constitute legal compliance, large organizations use standards as a shared vernacular that transfers across most jurisdictions and business units. Further, these function as an attractive mechanism to signal reasonable effort, since no single regulator or vendor could or would credibly provide this assurance. Their adoption, especially under explicitly certifiable frameworks such as ISO/IEC 27701 [5] prime an affirmative defense to consequences of organizational missteps in the space.

Commercial tool providers build to standards as de facto requirements catalogs and market their alignment, which propagates the standard's choices into implementations at scale and can be offered as a product feature.

2.3. Large organizations

My position is that the largest organizations absorb this, although they are still undeniably accountable to adhere to all applicable laws as a function of their costs of doing business. The top 100 multinational enterprises average more than 500 affiliate companies across more than 50 countries [6], and it is reasonable to assume each affiliate generates personal data compliance obligations in some context. Even organizations that could support legal teams in every country (and they often cannot) would not thereby assure compliance, given the technological detail involved and privacy's highly contextual nature. Further, over half of privacy programs are run out of legal departments [7], with the implication that the value of data structure and a technology backbone for compliance may not be fully appreciated within the function that owns it. In parallel, privacy-related spending

is accelerating. The share of large organizations spending more than \$5 million USD annually on privacy grew from 14% to 38%, and 93% of organizations with at least one dedicated privacy professional report plans to increase privacy and data governance investment over the next two years [7].

2.4. Commercial privacy tools

Commercial tool providers aim to fill the void created by the regulatory landscape and organizational desires to comply. These tool publishers play a needed role and offer the prospect of real value for their customer's money, especially for lower-maturity organizations faced with the challenge of creating something from nothing to get better at privacy, as they aim to reduce their exposure and risk.

However, commercial tool providers experience several practical constraints to perfect data structures within their tools, resulting in a functional parsimony in their features relevant to this problem.

- Their products are expected to be usable across a wide range of customer maturity levels. That is, a mid-market enterprise in a lightly regulated industry and a highly regulated Fortune 100 large enterprise must rely on the same core data structures.
- There is limited appreciation for technical correctness for the sake of technical correctness, especially when it comes at the cost of usability.
- Technical correctness may increase complexity, thereby increasing the potential for rework, reduced stability, and administration costs.
- They must make a profit.

The net result of these is that the vendor is actually managing the data model for organizations that implement these commercial tools, and that data model makes many decisions that may be latent or unrecognized at the time of purchase, where a subset of these carry risk implications the implementing organization never explicitly accepted. Further, the degree that extensibility of the data model is supported may create an invisible maturity ceiling, where the organization desires to extend its data model but cannot due to feature limitations. While my assertion is not that commercial tool publishers intentionally create these ceilings in their products, it is fair to acknowledge that commercial tool providers' interests are not perfectly aligned with those of their customers.

2.5. Ontologies, taxonomies, and schemas, oh my!

There are hundreds of ontologies, taxonomies, and other references written on how to perform selected tasks in data privacy, where these are understood to suggest either explicit or implicit data relationships. I suggest these are authored by sources that can be broadly characterized in four types: independent standards organizations, governmental or regulatory institutions, commercial organizations, and academic institutions. While not the fault of any author, by virtue of not being subject to harmonization in most cases, each body of work inherently has a

different level of analysis because they are scoped through charter and developed through consensus, not an individual organization’s needs. Further, interoperability with related external concepts (i.e., those outside of the explicit scope of the implied data structure) is not a widely seen feature or requirement of these. The result is that these issues may be invisible within the domain because the data relationships implied through the standard are fully valid from that vantage (internal validity). However, the resulting incompatibility becomes visible when the organization attempts to operate several of these at once within adjacent process subdomains. Lastly, a notable exception would be standards authored by independent standards organizations, which do regularly possess this feature of cross-subdomain compatibility, although this is almost always exclusively offered to other standards of their shared authorship.

No one has made a comprehensive reference data model, although the most foundational single framework in this space is the World-Wide Web Consortium (W3C) Data Privacy Vocabulary (DPV) [8]. This is a credible ontology that seeks to explain the interactions between organizations and regulations for data privacy. It publishes concept schemes for personal data, purposes, processing operations, legal bases, entities, risk, technical and organizational measures, and rights, together with a light layer of object properties connecting them. An ontology, fundamentally, shows the interactions between things. The DPV does this well, and this work takes the position that its foundational data relationships are correct for its level of analysis. It is an excellent basic starting point, and any solution in this space is aided by resembling it.

However, ontologies generally, and the DPV specifically, lack attribute-level detail, which makes them less suitable for off-the-shelf implementation within an organization. The distinction matters because a vocabulary answers “what concepts exist and what may relate to what,” while an implementing organization must answer “which records are first-class, what identifies them, which relationships are mandatory, and what happens to them over time.” These are different questions, and conflating them is the root of common failure modes examined in Section 4.

2.6. Where the DPV stops

Before this work performed any extraction, the DPV was examined as if it were schema-complete to surface the points where ambiguity in structure would otherwise pass into an implementation. The examination yielded eight categorical gaps, numbered 1 through 8, summarized in Table 1 as categorical concerns for implementation of the DPV and Table 4 as design deficiencies for a closure by the proposed solution.

Four of the eight concern static structure. The DPV expresses that a processing activity *may have* a purpose but never how many it must have, whether one is required, or whether multiplicity is bounded, and these are cardinality commitments any record system must make (gap #1). No commitment exists as to what identifies an instance of a concept, leaving keys, uniqueness constraints, and the distinction between a category and an occurrence to implementers (gap #2). Concept schemes do not constrain attribute data types, ranges, or formats, so conformance

cannot be validated without first being defined (gap #7). And the vocabulary takes no position on which records must exist for a program to be conformant, leaving the floor undefined (gap #8).

The other four relate to change over time. Most DPV concepts carry no states or transitions, yet nearly every operational record moves through draft, active, suspended, and retired states with rules about which transitions are permitted (gap #3). These assertions carry no from/until semantics by default, making it impossible to answer “which legal basis applied on this date,” a question regulators ask routinely (gap #4). Further, there is no mechanism for representing the change history of an entity or assertion, which defeats any automated monitoring control or audit engagement that seeks to reconstruct past activity or states (gap #5). Lastly, metadata cannot attach to a relationship without promoting the relationship to a node, an acknowledged problem (gap #6).

Table 1. The eight categorical gaps between the DPV and an implementable schema.

Gap	Concern	Commitment left to the implementer
1	Cardinality	How many of each related concept must or may exist
2	Identity	What identifies an instance, including keys, uniqueness, and category versus occurrence
3	Lifecycle	Which states a record moves through and which transitions are valid
4	Temporal validity	When an assertion holds (from/until semantics)
5	Versioning	How change history is represented and reconstructed
6	Edge provenance	How metadata attaches to a relationship (promotion to a node)
7	Enforceable typing	Datatypes, ranges, and formats permitting mechanical validation
8	Mandatory records	Which records must exist for a conformant program

These are not asserted to be flaws in the DPV. They are issues largely implicit to the application of ontologies in a discrete manner. However, disregarding any one of these eight gaps during an implementation is guaranteed to result in an underdeveloped data model, because each reflects a choice that will be made somewhere, whether explicitly by the implementer or implicitly by whatever tool(s) adopt the data model.

2.7. Maturity, regulation, and risk

In short, the gap between the DPV and an operating data model cannot be closed by a single fixed schema because the correct structure is a function of three independent variables. The first is *target maturity*. For this work, we ground in the Capability Maturity Model Integration (CMMI)[9], using the continuous representation, where each privacy capability subdomain carries its own level (L1–L5) rather than the organization holding a single rating. Informally, L1 describes ad hoc, individually held practice. L2 describes managed practice with records that exist as maintained data. L3 describes defined practice with records

connected to a common organizational structure. L4 describes quantitatively managed practice whose records carry history, validity, and provenance sufficient for measurement. L5 describes optimizing practice where those records feed automated monitoring and improvement. The data model manifestations of L4 (versioning, immutable histories, temporal validity) would be unnecessary, counterproductive overhead at L1, which is why maturity must parameterize the model rather than the model presuming a single maturity level.

The second variable is the *regulatory portfolio*. A single processing activity may be simultaneously subject to GDPR, CCPA/CPRA, LGPD, and sectoral obligations, and no single regime deserves to be privileged as canonical.

The third is *risk tolerance*, because a meaningful set of design choices has no single correct answer and ultimately resolves against the organization’s risk tolerance and appetite, as a function of how detailed the organization desires to be on a particular configuration decision. Together, these three variables define the design problem the reference model must solve and the reason its answer must be parameterized rather than prescriptive.

3. METHODOLOGY

The reference data model was produced through a phased approach where each phase delivered an input to the subsequent phase. This allowed successive phases to increase abstraction (supporting data structure normalization) over the project and mitigated issues originating from premature optimization. This pipeline’s output is the evaluated model presented in Section 4. At a high level, the phases were 1) preparation of the DPV skeleton and definition of subdomain boundaries, 2) identification and scoring of input taxonomies, 3) extraction of implied data entities, attributes, and relationships within these taxonomies, 4) normalization within each subdomain, 5) cross-subdomain joining, 6) technical evaluation, and 7) final reconciliations and application decisions. Table 2 summarizes the key results produced at each phase.

Table 2. Methodology key figures by phase.

#	Phase	Key result
1	Prepare DPV skeleton	12 subdomains defined
2	Identify input taxonomies	45 accepted, +9 supplemental
3	Extract entities, attributes, relationships	578 unique implied relationships (approx. 480 raw entries)
4	Normalize per subdomain	160 candidate gaps and decision points, 36% average compression
5	Cross-subdomain joins	87 joins mapped
6	Technical evaluation	100 test cases over 12 runs, approx. 12% footprint change
7	Final reconciliation	gaps discussed with the W3C

The DPV, as an ontology, does not consider object attributes, typing, or keys, and it must be prepared to receive these during operationalization. This requires the creation of boundaries that form domains of related concepts, where the number of two-way cross-boundary relationships should be minimized. The model

leans heavily on the DPV’s module structure to define its subdomains, representing the process areas within a privacy program at a large organization that implements the data model. However, decomposing the DPV’s module structure would have left common operational processes and artifacts without a home, including but not limited to Notice, Incident, and Regulatory Filing, as these are not first-class DPV modules. This resulted in a twelve-subdomain structure, enumerated in Table 3. A thirteenth candidate, Technology & AI Governance, was considered and set aside because its regulatory environment remains insufficiently stable to source authoritatively, and this is revisited in Section 5.3. This also happens to align with this domain’s current status within the most current DPV, where it has been contemplated and drafted, but not at the same depth as other entities and relationships.

Table 3. Process subdomains of the reference model by functional cluster.

Cluster	Subdomain
Processing spine	1 – Processing Inventory
	2 – Purpose Specification & Governance
	3 – Inventory & Classification
	4 – Legal Basis Management
	5 – Entities, Roles & Accountability
Individual-facing operations	6 – Consent Management
	7 – Data Subject Rights Management
	8 – Notice & Transparency
Defensive operations	9 – Risk & Impact Assessment
	10 – Controls and Measures
	11 – Incident & Breach Management
Regulatory interface	12 – Regulatory Reporting & Disclosure

3.1. Characterizing the DPV and identifying subdomains

As described in Section 2.6, the DPV was examined as if schema-complete before any extraction of entities or relationships was performed, producing the eight categorical gaps. I once again emphasize that these gaps were *mostly* not the result of deficiencies in the DPV’s design, but those associated with and arising from implementing ontologies as data models generally. This approach, that is, enumerating these structural issues before any analysis of individual entities or relationships, was intentional. Specifically, its purpose was to create a series of checks that could be applied at each phase to ensure that decision points were not being inherited or remaining latent but rather being explicitly decided as a result of this work. This provided the additional benefit of seeding the initial decision register.

3.2. Identifying authoritative sources per subdomain

Input taxonomies, that is, the sources that provide the raw material of data entities, relationships, and attributes for the data model, were identified through research targeted at subdomain/author-type pairs. It is important to note that these

Table 4. The gaps between the DPV and an implementable schema.

#	Gap
#1	Rules for whether a relationship is required or optional.
#2	No definition of what uniquely identifies an instance.
#3	No lifecycle states or rules for moving between states.
#4	No start or end dates on assertions.
#5	No way to represent the change history of a record.
#6	No way to attach metadata directly to a relationship.
#7	No enforced data types, ranges, or formats for attributes.
#8	No minimum set of required records for a conformant implementation.

sources may not have been explicitly labeled as ontologies, taxonomies, or reference data models. Rather, they represent commonly accepted ways to structure processes to perform tasks within their subdomain and had the common thread of being detailed enough in that endeavor that they explicitly and implicitly defined the most common data entities, relationships, and attributes required for the tasks they purported to standardize. The author typing approach asserted that credible authors could be classed into four groups: 1) independent standards organizations, 2) governmental or regulatory institutions, 3) commercial organizations, and 4) academic institutions. For each pair, searches were conducted using keywords (e.g., “taxonomy,” “ontology,” “classification system”) through internet search engines and bibliographic databases. Identified input taxonomies were coded by the subdomain(s) where they were suspected to imply relevant data entities, attributes, and relationships, then scored using a qualitative three-tier rating system for domain relevance, level of authority, and potential yield to the data structures of the reference model. Some input taxonomies were eliminated at this stage for having low potential yield, whether through low quality or a lack of implied data structures, or for being a summarization of another, more authoritative source of near-identical information. Selecting the highest quality of up to three per subdomain produced approximately 45 accepted input taxonomies and 10 supplemental sources, where some sources served multiple subdomains. The full listing and subdomain mapping appear in Appendices A and B.

3.3. Extracting the structure each source implies

Each source was analyzed for the entities, attributes, relationships, states, and cardinality constraints it explicitly stated. Many sources, especially those within the governmental or regulatory institutions author category, were observed to hold short of declaring requirements for data structures directly but proxy these through use-case-specific taxonomies, examples, templates, or written content. Where these implicit data structure artifacts could be deduced, they were captured based on the entities they implicated. Notably in the governmental or regulatory institutions author type, there was a class of input taxonomies that were preliminarily identified as among the highest quality and most authoritative sources that were ultimately set aside with limited benefit. These were best characterized as “example reports”, where the authors, almost exclusively regulatory enforcement

authorities, were representing a presentation view of synthesized data relationships that they would expect to see in their context, rather than the underlying data relationships. A common example of this is the GDPR Article 30 Report, commonly a “Record of Processing Activities”. In this class of document, whose design is based heavily on regulator-published templates that influence commercial tool design and organizational application of data models, several distinct entities and their relationships are “flattened” into a singular tabular row optimized for regulator overview. This has the second-order effect of obscuring the underlying structure that subsequently causes confusion about data relationships and encourages errors in data management and application.

Fundamentally, the productive insight of the extraction phase is that the data model of a regulation or standard often sits in implicit form within its operational guidance. Fields contained within mandatory disclosures, retention schedules, and template forms constitute primary evidence of required data and structure. In total, 578 unique relationships were implied across the source set.

3.4. Normalizing within each subdomain

Per-source extractions were synthesized within subdomains into a single subdomain model prior to any cross-subdomain joins being mapped. While there was an early expectation that duplicates be removed, there were a number of small semantic differences that required reconciliation. These were essentially concepts that had common and often near-identical definitions in plain language but used different terminology to summarize them across different sources. A prevalent example is the data entity representing the individual whose personal data is processed. This appears as a “data subject” under the GDPR and DPV, a “consumer” under the CCPA/CPRA, a “data principal” under the DPDPA, and simply as an “individual” across the NIST corpus. These four labels (and more with regulatory extension) represent a definitionally near-identical concept that requires reconciliation to a canonical entity that is also burdened by requirements of preserving source terminology as an alias for downstream uses.

These issues were initially reconciled at this stage but would be a theme throughout the work and are now understood to be table stakes of this type of forced-fitting approach. Basic checks were also performed at this stage to ensure a consistent level of normalization had been applied to each subdomain’s data structures. Where disagreements between two or more entries were identified, these were resolved within the subdomain at this stage, and decisions related to duplication, disagreement, and cardinality were noted for each entry.

This step matters because sources disagree more than their individual authority would suggest, with over 100 disagreements documented across the corpus, concentrated on cardinality, lifecycle, primary-entity designation, and taxonomy composition. This highlights earlier assertions that each input taxonomy was authored to satisfy only its own scope, and reconciliation across sources is typically not within that scope. For implementers, this deferral can have real implications tangential to organizational forces and pressure, which creates an opportunity for latent, in-

consistent, or otherwise poor decision-making to infiltrate data structures.

3.5. Cross-subdomain joining

Upon completion of entity-relationship mapping within subdomains, cross-subdomain joins were mapped using the DPV module relationships as a loose foundation, and work items placed held from individual subdomain views were then reconciled. This produced approximately 90 cross-subdomain joins and resulted in the first draft of the full model. It also surfaced a set of “messy middle” artifacts that matter operationally but either lack a clear home or near-evenly span multiple process subdomains. A common theme was that most of these are instantiated, so each instance appears as a subdomain-local entity until forced to confront cross-subdomain joins. Examples include AccountabilityArtifact (spanning over 20 typed document subtypes), Notice, and ImpactAssessment. These become first-class unifying classes in the model and are discussed in Section 4.4.

3.6. Evaluation

The evaluation approach focused primarily on the internal validity of the model, as external validity faced some constraints at this stage with time, level of effort, and information access required. I generally consider that internal validity here means the technical accuracy and completeness of the data model, where external validity is the data model’s fit for use and application in implementing organizations.

For the internal validity pillar, the data model was declared as a hybrid OWL/RDFS ontology in Turtle (.ttl) format, essentially making it machine-readable and compatible with common ontological tool sets. One hundred test cases were then built, informed by the NIST Privacy Workforce Taxonomy [10] and the IAPP Privacy Operational Lifecycle [11], representing common tasks performed in large-organization privacy programs. Each test case was written in plain language as one or more satisfaction claims, and each claim was then translated into a SPARQL [12] SELECT query. SPARQL was selected over relational alternatives because ontologies and their tooling natively support the more complex join patterns, such as tuples, that are pervasive in this problem space. The compiled test cases were run through a purpose-built Python schema validator informed by a selection of evaluation criteria drawn from Staab and Studer’s *Handbook on Ontologies* [13], where the validator was built using RDFLib [14]. The validator applied test cases that checked for likely missing entities, format gaps, missing relationships, missing attributes, typing gaps, mismatched domains, and mismatched output ranges.

One representative test case asserts the satisfaction claim “for a given processing activity, return the lawful basis in force on a specified date, together with the party that held the controller role at that time.” Its SPARQL translation (Table 5) exercises two reified associations (LegalBasisAssignment and PartyRoleInActivity), their temporal validity attributes, and two cross-subdomain joins in a single query. A claim of this shape is unanswerable against the unimplemented DPV and within many commercial tools.

This is not because the concepts are missing, but rather the missing feature manifestation of the earlier highlighted gaps, #4 (temporal validity) and #6 (edge provenance). The test suite is, in effect, a mechanized approach to assess whether the model is technically correct, complete, and closes the original foundational gaps that were asserted as necessary for practitioner use.

Table 5. A demonstrative representation of the referenced test case, annotated by query block. The ex: namespace denotes test fixture data.

Query (SPARQL)	Explanation
SELECT ?legalBasis ?controller WHERE {	Declares the two required answers to the test case, the lawful basis and the controlling party.
BIND(ex:ACT-0042 AS ?activity) BIND("2026-06-15")^^xsd:dateTimeAS AS ?asOf)	Defines the required inputs, the processing activity and the as-of date.
?activity ref:hasLegalBasisAssignment ?lba . ?lba a ref:LegalBasisAssignment ;	“Bridge” for the activity to its LegalBasisAssignment.
ref:assignmentOfBasis ?legalBasis ; ref:attributedToParty ?pra ; ref:effectiveFrom ?lbFrom . OPTIONAL { ?lba ref:effectiveTo ?lbTo } FILTER (?lbFrom <= ?asOf && (!BOUND(?lbTo) ?lbTo > ?asOf)) ?pra a ref:PartyRoleInActivity ;	Keeps only the assignment whose validity window covers the as-of date.
ref:bindsActivity ?activity ; ref:bindsRole dpv:DataController ; ref:bindsParty ?controller ; ref:effectiveFrom ?prFrom . OPTIONAL { ?pra ref:effectiveTo ?prTo } FILTER (?prFrom <= ?asOf && (!BOUND(?prTo) ?prTo > ?asOf)) }	Resolves the attributed PartyRoleInActivity to a party holding the controller role.
	Filter acting as a guard to the role binding, so the returned party is the controller on the input date, if the controller has changed since.

Running the suite began an iterative process (run the validator, resolve apparent issues, run it again) that converged at 12 iterations. At this point, those that remained were decisions reserved for the implementer (Section 4.8) and represented stylistic choices of approach and risk tolerance, rather than the construction of the data model. The model’s footprint changed approximately 12% between the pre- and post-evaluation states, with results mostly “building out” cross-domain relationships and necessary reified entities in the “middle” of the data model. I assert this degree of change establishes the initial evaluation was

substantive rather than confirmatory.

For the qualitative pillar focused on the data model's fit for use as an application of the DPV, I considered several factors that would have been constraining to the quality of this work, ultimately opting to take a limited approach in this space at this stage. These factors included but were not limited to:

1. There may be less than 5,000 organizations who would have appropriate justification to implement such an approach. While other organizations beyond this may certainly benefit from this on a piecemeal basis, we must broadly consider that organizations do not seek to “do better” at legal compliance for the sake of artfulness.
2. Exploratory conversations with stakeholders from likely candidate organizations highlighted the need to first, but near-simultaneously, qualify the problem for the organization. While it is likely that any candidate organization meeting certain size and geographic minimum criteria could benefit from this work, recognizing a bona fide need for the value (through elimination of rework and pain) of implementing such a data model is a real prerequisite for quality of evaluation and implementation.
3. The individual who can qualify the intersection of the problem space and the organization is not necessarily the individual who can evaluate the data model's fit for use and application on behalf of the organization.
4. Such an evaluation could take several to several dozen hours per evaluator/organization. Lesser attempts at this would create potential to undermine rigor in evaluation and introduce anecdotes that could erode internal validity.

More broadly, we consider that the approach used to construct the data model inherently selected for valid sources. That is, almost all input taxonomies were themselves subject to standalone reviews by their respective authoring entity (e.g., standards bodies, regulators, etc.), which often included formal development processes, expert evaluation, public preview and feedback, and other rigorous tactics. The model therefore inherits a meaningful degree of external validity from its sources, in the sense that its raw material was already heavily vetted, even though the composed whole has not yet received equivalent scrutiny.

Lastly, I did approach the W3C Data Privacy Vocabularies and Controls Community Group in an attempt to gain some additional perspective on the external validity of this work. However, this work is best characterized as a DPV implementation, where the group takes a policy position to not comment unless articulated back to a specific perceived issue or deficiency in the DPV. My work identified 13 potential issues in the DPV, of which further research indicated that 10 were known already. I raised these issues and discussed the feedback approach and requirements through informal channels (standing group meeting) and will formally raise these issues with suggested fixes that are within the purview of the DPV concurrent with future updates to the reference model.

Expanding on both external evaluation and partnership with the W3C working group is further discussed in Section 5.

4. A REFERENCE DATA MODEL FOR ORGANIZATIONAL PRIVACY MANAGEMENT

This section presents the model's features, structures, and the analytic observations or findings that underpin them. It proceeds from general to specific. A reader should finish this section understanding the model's composition, including its regulation-agnostic spine (4.2) the parameterizing layers for regulation, maturity, and risk (4.6–4.8), and why a defensible alternative composition would be adjudicating decisions that are materially the same as observed within this work.

4.1. Data model shape and positioning

The structure needed for implementation far exceeds the vocabulary within the DPV. While previously mentioned as expected due to the DPV's ontological roots, the analysis sustained this idea empirically. The reference model contains 34 core entities, 65 core relationships, 12 reified-association classes, 51 per-subdomain entities, 37 per-subdomain relationships, and 87 cross-subdomain joins, roughly an order of magnitude more structure than the DPV publishes. Although it would likely be apparent, it must be said that implementers should not treat DPV adoption as sufficient for operating a privacy program. Whether this reference model is used or another is originated, the implementation layer cannot be skipped without producing a failure mode that sounds like “we did the DPV and still don't have a working operating model.”

The reference data model organizes this surface as three rings. The first is an invariant core, a “clean core” of entities and relationships that organizations should modify only at their peril, because they represent realities the organization does not control, and because modification either represents a misunderstanding of the underlying concept or undercuts the intended normalization, creating downstream data quality problems. A representative case is `PartyRoleInActivity`, which is a reification of the role a party holds in the context of a specific activity rather than typing this role onto the party itself. An organization that adopts the common pattern of collapsing this into an attribute of `Controller` or `Processor` achieves a simpler structure at the cost of no longer being able to represent acting as a controller in one context and as a processor in another, which is an ordinary occurrence in large enterprises. Further, without this recognition, every downstream obligation keyed to that role is compromised.

The second is a flexible periphery, organized by capability subdomain, which primarily expresses the applicability and implementation of particular controls and the artifacts they generate. It is expected that organizations might modify these more freely in accordance with their objectives and risk tolerance.

The third is a set of profile extensions, applied only when scoped under a specific regulation, where regulation-unique entities and relationships live. The CCPA/CPRA profile provides an excellent anecdote around this, where this regulation contributes to the idea of selling and sharing personal data as a unique data action that would otherwise just be encompassed as a typed instantiation of `ProcessingOperation` for GDPR, handled through the model's invariant core. However, CCPA/CPRA makes onward

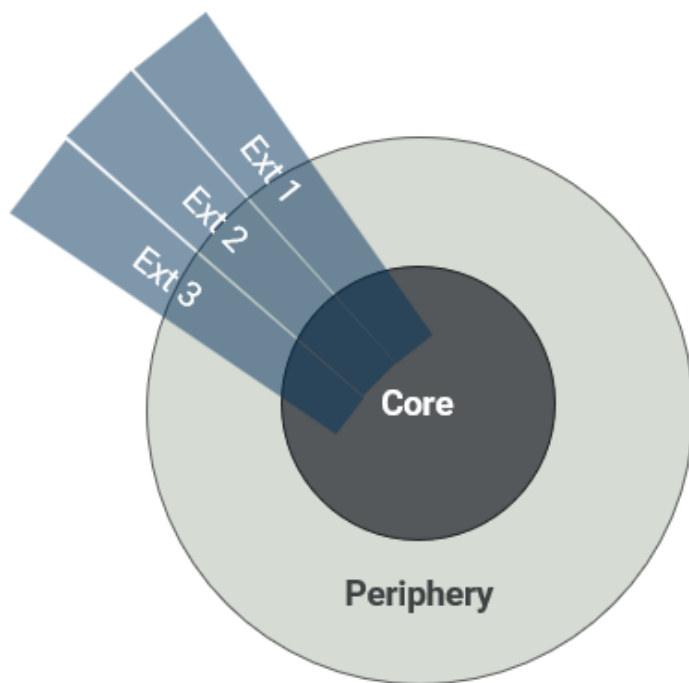


Figure 2. Theoretical visualization of Core, Periphery, and Regulatory Extensions.

obligations related to this type of activity through associated opt-out preferences and signal handling requirements, which have no counterpart in the GDPR’s lawful basis and objection approach. This suggests that the concept is not defensibly placed within the regulation-agnostic core and necessitates a place within a regulation-specific extension framework.

Notably, all three rings ultimately distill down to entities, relationships, and attributes, regardless of where they fall. Necessary for the application of governance, they allow for recognition of the distinction between required and recommended (functionally the same in this model) versus optional. This serves to create the space for maturity keying and regulation-specific overlays later.

4.2. The regulation-agnostic spine

The core was held to be strictly regulation-agnostic, with regulatory requirements addressed through a combination of abstraction, entity typing, and regulation-specific entities and relationships within extensions. When regulation profiles for the GDPR (European Union), CCPA/CPRA (California, United States), LGPD (Brazil), and DPDPA (India) were created, there was limited divergence from the core relationships. While there was the appearance of some semantic incompatibility initially, these more reflected differences in the cultural and political framing of each regulatory regime rather than a genuinely different approach to encoding the operational reality of who is processing which data, for what purpose, under which legal authority. An interesting example of this is the DPDPA’s *Data Fiduciary* concept versus the GDPR’s *Controller*. Fundamentally, the former invokes a general duty of trust, whereas the latter confers author-

ity over purposes and means of personal data processing. This is fundamentally a legal-cultural difference rather than a difference in how operational facts are encoded; both resolve to the same *PartyRoleInActivity* assignment, with the divergence surfacing in the profile overlay and via Subdomain #12 (Regulatory Reporting & Disclosure) rather than in the core.

Ultimately, these are not dissimilar to the issues experienced earlier during entity-relationship mapping, where two identical concepts had differing terminology under differing standards or regulations. Anecdotally, this close fidelity of core relationships transcending modern regulation likely draws its origins back to various canonical works in data privacy, including the modern-day FTC Fair Information Practice Principles articulated via the 1973 HEW report on automated personal data systems [15] and the OECD Privacy Guidelines (1980) [16].

The data model is contemplated to contain entities (*ProcessingActivity*, *Purpose*, *PersonalDataCategory*, *LegalBasis*, and *PartyRoleInActivity*) that should appear in every conformant implementation, at every maturity level, under every supported profile. *ProcessingActivity* is the closest thing that could be reasonably called the “center” of the spine, with *Purpose* attaching through the processing-for-purpose relationship, *PersonalDataCategory* through processing-of-data, and *LegalBasis* attaching, at L3 maturity and above, through the *LegalBasisAssignment* reification so the assignment can carry its own dates and evidence. *PartyRoleInActivity* is itself a reification of role-in-activity, which is what permits the same party (legal entity) to hold different roles in different activities. This reflects, especially in large organizations, the increased prevalence of one legal entity routinely holding a role as a controller in one activity and a processor in another. This corrects a common normalization flaw where typing roles onto parties directly rather than onto their participation creates inaccuracy as to a party’s role and thus their specific obligations. It is recommended that a privacy program implementing the data model should establish these five classes first, regardless of which regulations drive its program.

In summary, privacy regulations are doing a lot of the same things in sometimes different words. Reading any single regulation suggests that everything it names is required structure, but comparison across regimes shows that regulations bundle their requirements with regime-specific field names, templates, and enumerations. Even a reading of multiple regulations in a sitting may not make this initially apparent, due in part to the topic breadth of modern comprehensive privacy laws. This reconciliation, as well as the implicit concepts that regulations assume, such as organizations having their own structures and hierarchies to organize and articulate their work, is what forms the spine of the data model.

The choice to route the regime-specific portion to overlays (GDPR Article 30’s mandatory record fields being the canonical example) is what lets the core hold at 34 entities and 65 relationships across all four profiles. This sustains the value proposition of a reference implementation for organizations holding at least two differing regulatory obligations. I contemplate the costs associated with implementing a common data model are offset as

regulatory complexity increases, which is expected, especially for large organizations.

4.3. Normalization and Reification

A meaningful subset of the entity relationships cannot remain simple edges once they are tracked comprehensively (i.e. cross-subdomain, with all relationships reflected), because operational reality requires that they carry their own metadata. Examples may include which legal basis applied to which activity at what point in time, which role a party held when a consent event occurred, or what evidence was logged when. This reflects a truth of data engineering that edges do not carry data, only entities can. As a result, the model promotes twelve associations to first-class reified entity classes. These are `PartyRoleInActivity`, `LegalBasisAssignment`, `ConsentEvent`, `ClassificationAssignment`, `IdentityStateTransition`, `NoticeDelivery`, `Mitigation`, `Notification`, `SubmissionSnapshot`, `RoleFlipEvent`, `RightExerciseActivity`, and `EffectivenessReview`.

The pattern is consistent across all twelve. Each represents a fact about a relationship that the organization must be able to date, attribute, evidence, or version independently of the endpoints it connects. A `ConsentEvent` is a dated, attributable occurrence with a capture mechanism and a withdrawal path, not a bare “data subject consents to purpose” edge. A `SubmissionSnapshot` freezes a defensible record of exactly what was filed and when. A `RoleFlipEvent` captures a party’s controller/processor posture changes for an activity the moment it occurs, which is also representative of the kind of transition that is commonly subject to regulatory scrutiny and fault (that also happens to be erased when working with edges). The DPV does acknowledge this underlying need but treats such promotion-to-node actions as a workaround (see gap #6 as this is related). The data model treats these as foundational implementation patterns because every relationship requiring versioning, evidence, temporal validity, or attribution requires it. Building on this, data architectures targeting L3 or above maturity should implement these as first-class entities from the start because designs that leave them as edges force a large rework at L4 with significant cost overheads observed in maturity analysis (Section 4.7).

4.4. Things without a clear home

Several things observed in widespread usage, “things” used in an ontological sense, simply don’t sit cleanly in any single capability subdomain. Instead appearing across many in subtly different forms. Documents and assessments produced for accountability, transparency, and risk purposes serve cross-subdomain functions but are originated within whichever subdomain triggered them, so per-subdomain analysis renders each occurrence as a local entity. Only the cross-subdomain view typically pinpoints the shared parent. Ultimately, three unifying classes emerged from more detailed examination of this issue. `AccountabilityArtifact` is the abstract parent of at least 23 identified typed document subtypes spanning data processing agreements, joint-controller arrangements, sub-processor authoriza-

tions, and consent records, among others, with intentional support for infinite extension. `Notice` is a thin abstract parent whose subtypes are co-owned by the subdomain triggering its instantiation. Examples encompass types such as notices at collection, supplemental just-in-time notices, notices of changed processing, and rights-response notices. Each of these `Notices` as triggered by independent mechanisms but shares `NoticeDelivery` and common data structures for versioning and publication within Domain 8 (`Notice & Transparency`).

`ImpactAssessment` is polymorphic over the DPIA, PIA, FRIA, and TIA variants and theoretically allows for limitless extension. Modeling these as shared parents rather than parallel local structures prevents drift between equivalent subtypes, reduces redundant fields, and centralizes the audit and retention logic that would otherwise be replicated across subdomains. It also reflects a practical reality that large organizations assess activities broadly across geographic boundaries and abstractions of harm types (e.g. harms to the organization, individuals, and society).

4.5. Connecting subdomains

The 87 cross-subdomain joins cataloged in the model exist because forced interoperability was a defining design constraint. Each subdomain produces or consumes structure that other subdomains need, and the join inventory is the basis on which inter-subdomain consistency can be planned. Beyond being informative, this also enables monitoring use cases associated with higher maturity levels, mitigating the need to “rediscover” a change every time a subdomain is touched. Expanding on maturity, these joins play a key role in enabling the maturity keying features (Section 4.7) of the data model because joins require compatible structures on each endpoint. Entities, Roles & Accountability participates in 23 joins, the most of any subdomain, consistent with its role as the model’s accountability backbone and the place where all obligations must pass through on query (Table 7).

4.6. Accounting for regulation

Regulation attaches to the spine as profiles. Profiles can be conceptually visualized as overlays. They specifically add mandatory concepts not otherwise addressed through a regulation-agnostic approach as entities and relationships, and occasionally attributes or types. Four full profiles (GDPR, CCPA/CPRA, LGPD, DPDPA) and a small set of sectoral skeletons (e.g., HIPAA, GLBA) were composed for this exercise. The design consequence is that operating under multiple regulations more closely resembles a composition problem than a reconciliation one. Because no regulation scheme is reflected in the core, multi-regime processing is supported by implementing the core data model and selecting the appropriate overlays. This has the somewhat intended consequence of surfacing conflicts for explicit assessment, handling, and decision, rather than being latent.

Consider a SaaS provider operating in both the United States and the European Union, with a single product-analytics processing activity touching personal data of California and EU residents. Under composition, the activity exists once in the core, with one `ProcessingActivity`, one set

of Purpose and PersonalDataCategory attachments, and one PartyRoleInActivity arrangement. The GDPR profile then overlays the Article 30 record fields, the lawful-basis constraint, and the EU-specific transfer mechanic. The CCPA/CPRA profile overlays its disclosure categories, the sale/share flags, and its opt-out semantics. The union composes without error or conflict because the overlays touch different attributes, and where the regulatory schemes do genuinely diverge (e.g. retention expectations) the divergence surfaces as an explicit decision on the composed record. Under reconciliation, by contrast, the organization must classify the activity as “a GDPR record” or “a CCPA record” and then bolt the other regime on as an exception, which is a commonly observed pattern in most commercial tooling today.

This reflects an intentional design decision where target organizations operate across multiple jurisdictions and may enter new ones. Bypassing the regulation-agnostic core for short-term convenience produces the regime-coupling problem the model exists to prevent. This further supports the idea that organizations with cross-jurisdictional processing should accordingly resist process designs and/or tools that demand a single regulatory classification per processing activity.

4.7. Accounting for growth and maturity increase

As large organizations seek to understand and control their privacy risk, they will likely desire to improve the process maturity within certain areas to provide assurance on privacy-relevant information and privacy controls. However, complex features (versioning, immutability of histories, temporal validity, edge provenance, and attestation) introduce unnecessary complexity at the lowest maturity levels that could threaten early and successful adoption. The model therefore contemplates these features separately, introducing them as between L3 and L5 that focuses on minimizing rework. Organizations that advance their maturity should expect to add these features to their clean core, and the model makes the cost of doing so explicit through 84 cataloged rework points across the twelve subdomains (Table 6). It should be noted that a key finding here is the uneven distribution of rework points, with L3→L4 as the cliff. This is mostly attributable to reification-validity semantics, the requirement that key associations carry versioning, temporal validity, and provenance.

Table 6. Rework points by CMMI transition, with the character of each transition.

Transition	Character	Rework points
L1→L2	Register existence	13
L2→L3	Spine assembly	14
L3→L4	Reification cliff	44
L4→L5	Automation	13
Total		84

Each transition has a distinct character. L1→L2 is essentially *register existence*, where the subdomain’s primary records come into being as maintained data at all, and the rework is uniformly low because there is little structure, no enforcement on that structure, and limited contemplation of entity-to-entity relationships.

L2→L3 is *spine assembly*, where local records connect to the shared core classes, terminology begins to align to a common vocabulary, and consideration for cross-subdomain relationships begins but is still tolerant for duplication through low normalization. L3→L4 is the *reification cliff*, showcasing more than half of the rework points because structures that existed as simple records and edges at L3 must be retrofitted to carry history, validity intervals, and provenance. L4→L5 is automation rather than new structure, where the data model largely stops changing and the rework concerns instrumentation, monitoring hooks, and the closing of feedback loops. An organization budgeting a program, “budgeting” here in a broad and not purely financial sense, can read its costs casually off this profile. An L3→L4 plan that funds process change and training without provisioning for time, funding, and technology to handle the versioned schemas and immutable event logs has ultimately underprovisioned the initiative, and it seems plausible to me that this is the next most common reason such initiatives stall.

In another dimension of change, it is also important to recognize that progress is rarely free. The model documents 36 cross-subdomain dependencies, where certain maturity improvements presuppose that adjacent subdomains are already operating at a minimum (i.e., change-compatible) level. If they are not, the dependent subdomain simply will not accept the data model change as a function of incompatibility. Entities, Roles & Accountability is the most depended-upon subdomain (7 inbound dependencies), followed by Legal Basis Management (6), which identifies these two as the highest-return early investments. Regulatory Reporting & Disclosure, by contrast, is downstream of nearly everything, consistent with the principle that a report should be a view over the inventories rather than hand-kept primary data. Together, the rework points and the dependency map allow investment to be articulated and planned against a delta map, rather than reverse-engineered from known past program deficiencies. This is one of the model’s headline practitioner utilities, making the costs of getting better estimable in advance by a mechanism of better forward view.

A final condition observed was the potential cost of operating at mixed maturity levels, which most organizations do in practice. Cross-subdomain joins require a degree of symmetry between their endpoints. When one side of a join operates at L4 and the other at L3, the L4 side must either degrade to L3 semantics across that join or use translation logic. Functionally, reification-validity semantics do not degrade gracefully, making translation approaches difficult in practice and leading to second-order effects such as losing provenance. This could force re-derivation (i.e., backsliding), which should be viewed as a kind of fault when it occurs. Functionally, this would be expected to occur during evolutions such as system migrations, M&A integrations, and legacy decommissions and should be flagged as risks to the program’s maturity and its data integrity, rather than being absorbed as IT work. Practically, an approach where level parity within connected clusters of subdomains is indicated, especially over maximizing any single subdomain in isolation. The full transition-level rework distribution and the pairwise dependency matrix appear in Appendix D (Tables 10 and 11).

4.8. Accounting for and expressing risk tolerance

Certain entities and relationships appear in neither the clean core nor any regulation or maturity overlay. These are discretionary at the lowest maturity levels, although they do become the source of dependency as maturity increases in both their own and adjacent domains. As a matter of technical correctness, imposing them as mandatory from the outset of implementation would be arbitrary, and resolving them in the model would impose a single risk posture on every adopting organization. That said, they are likely happening in large organizations already, and there may also be reasons for their implementations beyond risk tolerance, such as staff efficiency or for enabling monitoring in an adjacent subdomain. Ultimately, forty of these points, represented as implementation decisions, were identified and made explicit, each documented with its options and trade-offs. The full catalog appears in Appendix F (Table 12) and is browsable in the model explorer (Section 4.11).

Beyond entities and relationships, the work surfaced the importance of implicit taxonomies and taxonomy-like typing schemes in the design of and within certain attributes. This is fundamentally expressed in degrees of coarseness, where the more finely tuned the individual taxonomy, the more precisely risk is expressed. This contemplates that intentionally applied precision serves as an expression of risk tolerance within that area. A universally applicable example is the precision an organization uses to describe the unit types of personal data. The choice carries no inherent entity relationship, but an organization that believes it can describe all possible types of personal data in 30 options versus 100 versus 300 is inherently accepting risk through its apparent precision or lack thereof. A hospital may need to represent dozens of medical-specific personal data attributes because the varied sensitivity and abuse cases associated with diagnosis information differ from those of a common test result such as an EKG. However, a toy manufacturer may reasonably compress this same information under the single umbrella of “Medical Records”. Coarseness need not be uniformly applied, though, and these specific decisions remain a valuable lever for an organization to articulate its risk tolerance as part of the construction of its due diligence processes. This also reflects a practical reality that organizations must establish processes before they monitor them.

The same pattern recurs at larger scales. Orienting the risk taxonomy on harms, rights, or impacts is a defensible choice in every direction, with each orientation represented among the authoritative sources, and the choice propagates into assessment templates, mitigation typing, and regulator-facing narratives. Whether the four control themes inherited from ISO/IEC 27002 [17] are modeled as a class hierarchy or an attribute facet has no correct answer in the abstract, but carries material consequences for how controls are queried, inherited, and reported once thousands of instances exist.

Similarly, adopting a CMMI target of L2 versus L4 in a process subdomain is itself a manifestation of risk tolerance. However, it was observed that opportunity for discretion narrows as maturity rises. This is attributable to the many defensible decisions either way at L2 collapsing toward a single valid resolution once ver-

sioning and provenance requirements are implemented between L3, L4, and L5. This creates an imperative for organizations approaching a transition to resolve the relevant decisions before continuing.

Lastly, the relationship between large organizations and commercial tool providers must be confronted at this stage. The analysis also included an inspection of input taxonomies implemented by commercial tool providers, namely, the API schemas that reflect, to some degree, the design of their product’s own data models.

While I previously asserted that these decision points had no single correct answer, the degree to which commercial tool providers 1) recognize these as decision points, 2) subsequently recognize them as dimensions to express risk tolerance for the implementing organization, and 3) support customization and extension of these as features widely varies across the corpus of commercial privacy tools. This dynamic should create a few imperatives for organizations to ensure that any commercial tools they choose to employ will support appropriate extensibility based on their maturity requirements and ambitions, especially when making build/buy decisions.

In all cases, understanding where these decisions exist implicitly and taking steps to decide their design reflects an explicit choice to control risk with somewhat enumerated trade-offs, rather than implicit risk acceptance by default.

4.9. What the model looks like in each program area

While the previous sections describe the various viewpoints and requirements that inform the model’s design philosophy, this one walks through its functional mechanics. Table 7 summarizes the characteristics referenced throughout this walkthrough.

Of the twelve subdomains, these can further be grouped into four clusters that further illustrate the function, purpose, and distribution of entities and relationships.

Subdomains 1 through 5 (Processing Inventory, Purpose Specification & Governance, Personal Data Inventory & Classification, Legal Basis Management, and Entities, Roles & Accountability) together constitute the processing spine, and their shapes are instructive. Processing Inventory carries only 2 entities but 20 relationships and 17 cross-subdomain joins. It is a hub of interconnection that contains the context of organizational activities. Entities, Roles & Accountability is the model’s largest subdomain by every measure (12 entities, 30 relationships, 23 joins), consistent with its role as the accountability checking mechanism and its position as the most depended-upon subdomain in the maturity dependency map. Legal Basis Management is compact locally (5 entities, 8 relationships) but joins broadly (16), reflecting that lawful basis is asserted *about* other subdomains’ records rather than existing for its own sake. Personal Data Inventory & Classification carries the model’s densest attribute typing because it is where the unit-of-accounting and classification-scheme decisions of Section 4.8 land.

Subdomains 6 through 8 (Consent Management, Data Subject Rights Management, and Notice & Transparency) are best characterized together as individual-facing operations; these share

Table 7. Per-subdomain characteristics of the reference model, covering local entities and relationships, cross-subdomain joins, total maturity rework points, and dependency counts. Outbound dependencies count the subdomains this one must wait for. Inbound dependencies count the subdomains waiting on this one.

Subdomain	Entities	Relationships	Joins	Rework	Dep. (out)	Dep. (in)
1 – Processing Inventory	2	20	17	6	6	4
2 – Purpose Specification & Governance	2	5	6	4	5	2
3 – Personal Data Inventory & Classification	7	14	7	6	1	4
4 – Legal Basis Management	5	8	16	8	4	6
5 – Entities, Roles & Accountability	12	30	23	9	1	7
6 – Consent Management	4	10	9	6	3	2
7 – Data Subject Rights Management	5	9	5	6	3	1
8 – Notice & Transparency	5	4	6	7	0	1
9 – Risk & Impact Assessment	3	8	12	10	3	4
10 – Technical & Organizational Measures	4	9	7	8	1	1
11 – Incident & Breach Management	5	9	10	6	4	2
12 – Regulatory Reporting & Disclosure	5	3	5	5	5	2

a common thread of event-focused reification-dependent structures tightly coupled to the data subject’s point of view. Consent Management is built around the `ConsentEvent` reification and its withdrawal path. Rights Management is built around `RightExerciseActivity` and its time-sensitive workflow states. Notice & Transparency is built around `NoticeDelivery`, which converts “we published a notice” into “this notice version reached this audience through this mechanism at this time.” Despite being among the most visible obligations in privacy law, it has one of the thinnest subdomains (4 local relationships, the fewest in the model). This is because of the inherent relationship between notice and consent, where consent is often given pursuant to the specific terms of a notice. This “light” structure is not dissimilar from entities that exist primarily to summarize and present information mastered elsewhere, such as `AccountabilityArtifact`.

Subdomains 9 through 11 (Risk & Impact Assessment, Technical & Organizational Measures, and Incident & Breach Management) form the program’s risk and controls cluster. Risk & Impact Assessment is compact (3 entities) but carries the model’s highest rework total (10 points) because these assessments accumulate the most L4 changes that introduce detail necessary to more precisely assess risk. They also include versioned findings, Mitigation reifications, and `EffectivenessReview` support. It also joins broadly (12), because an assessment is fundamentally a claim about other subdomains’ records. Technical & Organizational Measures hosts the control-theme decision discussed in Section 4.8 and links the privacy program to the wider security control estate through loosely adherent NIST OSCAL-style structures [18]. Incident & Breach Management is where the `Notification` reification exists to bridge gaps between the organization, individual regulations, and individual breach obligations. Notification obligations extend per regulation and per authority. This is intentional and in contrast to the prevailing common approach that has notification modeled as an attribute of the incident. By doing this, it allows the demonstration of the timeliness of meeting notification requirements, which is a frequently enforced obligation within this subdomain.

Regulatory Reporting & Disclosure, subdomain 12, is deliberately the thinnest in the local structure (3 local relationships) and among the most dependent in the map (5 outbound dependencies).

This is a design position that considers the reports and disclosures made in this subdomain should be a view of the inventories, materialized through `SubmissionSnapshot` records for defensibility, and never primary hand-kept data. Maintaining a regulator-facing report as primary data is a maturity anti-pattern the model will not enable. The corollary, captured in the dependency map, is that this subdomain cannot reach L4 until many of its respective source inventories have.

4.10. Defining DPV <-> reference model handoffs, DPV gaps

The boundary between the DPV’s appropriate ontological scope and the reference model’s definition is an analytic result of this work. The DPV publishes concept schemes while the reference data model contemplates something that resembles a schema. Where an organization depends on regulation, maturity, or risk tolerance, it likely belongs within the reference model or below.

Against that boundary, the reference data model build identified 13 specific gaps in the DPV, of which at least three were previously undocumented. Ten of thirteen are substantively improved upon within this work.

The largest gaps concerned maintenance and freshness mechanics. Regulations and standards uniformly require records to be “kept up to date” while giving little guidance on how or freshness expectations. Across the entire input corpus, no surveyed taxonomy provided the mechanism to operationalize the requirement, leaving every adopting organization to originate the same structure independently. The reference data model closes this gap directly, originating a maintenance-status state machine supported by a freshness triad (last-reviewed timestamp, review cadence, and next-review-due) together with attestation and reviewer-identity attributes. The mechanism is introduced at L3, enforced at L4, and automated at L5, and it applies uniformly across the inventory and assessment subdomains. Retrofitting freshness metadata after the fact is among the most expensive periphery additions in the rework catalog. It is recommended that the freshness mechanism be adopted into every inventory and assessment at L3, even where the review processes it supports are not yet formalized.

4.11. The delivered artifacts

The model is delivered in two coordinated forms.

1. Machine-readable schema, a hybrid OWL/RDFS ontology in Turtle (.ttl) format of approximately 1,200 lines, compatible with common ontology tool sets such as Protégé.
2. The interactive Reference Data Model Explorer web application, available at PrivacyReferenceModel.com, which exists because the model's breadth does not present neatly on a single diagram. The explorer supports graph visualization with target-maturity filtering (which reduces complexity to the selected level), layer isolation across core, periphery, and profile extensions, and standalone catalogs for subdomains, entities, relationships, decisions, and maturity levels.

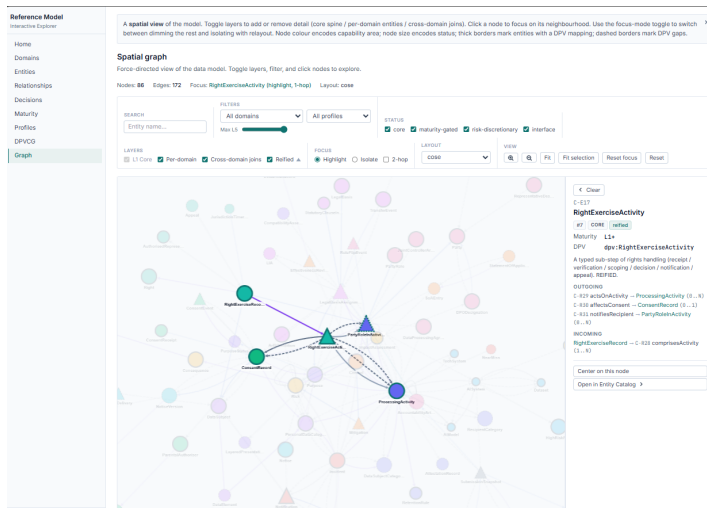


Figure 3. The Reference Data Model Explorer shows a focus on a particular entity and its associated metadata and relationships.

A third form is contemplated but was not delivered as part of this work. This will be an implementation guide that will include a documentation set, including the per-subdomain models with individual static visualizations along with the decision and maturity-delta catalogs. This is further discussed in Section 5.

5. LIMITATIONS, QUALIFICATIONS, AND FUTURE WORK

5.1. Limitations

Several limitations bound this work. First, the Technology & AI Governance subdomain was deliberately set aside because its regulatory environment and its position within the DPV [8] are still stabilizing. While there is no absence of available input taxonomies in the space, many lack detail to support modeling depth, and it is not yet clear who will end up with high levels of authority, ultimately substituting speculation for evidence.

Second, the internal validity evaluation, while systematic, stops short of synthetic-data stress testing. The 100 test cases validate the satisfiability of the model's structure, not performance or behavior under realistic data volumes.

Third, external validity is the weakest part of the work to date. The W3C working group does not typically comment on individual implementations; feedback on the submitted issues remains pending, and broader qualitative validation would require a high degree of screening on feedback subjects in a topic this specialized, an effort that exceeded the available time and effort.

Finally, the maturity grounding is CMMI-esque at best and should not be taken as a strict implementation of the appraisal requirements [19]. The maturity-delta, including its concentration cliff between L3 and L4, is likely a manifestation that there may be a more fit-for-use mechanism to express the intersection of process maturity requirements, risk tolerance, and required data. If restarting with this knowledge, the work could be made more concrete by abstracting CMMI and defining a single level of required minimum normalization per CMMI level starting with sixth normal form (6NF) or domain-key normal form (DKNF) for CMMI Level 5 and then working downwards from there. This would add a certain level of concreteness to the data structure model at each maturity level.

5.2. Qualifications

The claims of this work should be read under several qualifications. This is a reference model, not a standard. It carries no conformance authority, and the idea of a “perfect” data model is not that implementing organizations can be perfect, but that the model is a rigorous starting point from which implementers decide what is good enough for their organizations based on their own context. The published counts are a versioned snapshot against DPV 2.3 and the cited regulatory texts as of this writing. Source traceability guarantees provenance, not correctness. The input taxonomies themselves may err, and where they disagree, this work's resolutions are documented judgments rather than discovered facts. Applicability assumes the DPV framing and a CMMI-style maturity lens, and the model is oriented toward large, multi-jurisdictional organizations, so smaller or single-regime organizations may find portions of the periphery permanently out of scope.

The work should also be read against the adjacent efforts it does not replace. Commercial platforms embody the most complete privacy data models in practical existence, observable through their public API surfaces [20–24], but they are implicit, proprietary, and shaped by the vendor's need to satisfy a diverse customer base, and this work has not been evaluated against them directly. Academic privacy engineering work, including privacy-by-design methodology [25, 26] and threat-modeling frameworks such as LINDDUN [27], addresses how to analyze and design for privacy rather than what the operating data structures must be, and this model does not substitute for either. To my knowledge, no prior work has attempted a full-breadth, maturity-parameterized, regulation-agnostic reference data model for organizational privacy operations with the DPV as its semantic foundation. That novelty cuts both ways, because it also means no independent benchmark exists to compare the composed whole against, and this absence is part of why external validity remains the weakest pillar and such a large task to evaluate.

5.3. Future Work

I contemplate that there are at least five opportunities for future work building on this:

1. A full implementation guide should accompany the reference model, translating its structures into adoption sequences for organizations at differing starting maturities.
 2. Internal validity can be deepened through synthetic-data testing against the Turtle serialization.
 3. External validity can be expanded through a screened expert panel and subsequent continuous feedback during organizational implementations once scoping burden can be supported.
 4. There is value in this work as a diagnostic framework to help organizations assess their privacy program maturity and readiness via their data. This channels questions that sound like *What (data) do you have today? What (tasks) could/should operationalize next? What domains could be operationalized with relatively low cost?* and *What is the corpus of privacy program tasks that needs to be performed?*
 5. There may be merit in using the model as an evaluation instrument against commercial tools with the aim of pinpointing exactly what maturity level their implicit data structures imply, extend to, or max out at.
4. Target process maturity, while imperfect, is a valid way to express risk tolerance through logically related process groupings (subdomains). Maturity parameterization as a technique enables visibility into the process and data rework points that are required for maturity advancement. Understanding these rework points, dependencies, and decisions further allows for shifting of their corresponding expenses from largely “discovered after the fact” to planned, and the concentration of the cost cliff between L3 and L4 is also now known in advance rather than after a program has stalled.

6. CONCLUSIONS

This work began from the observation that privacy compliance difficulty in large organizations resembles a convergence problem, where implementing regulatory guidance, independent standards, or commercial tools each produces mostly valid work in isolation, with organizations holding the bag of data trying to make it all work together compatibly under the auspices of a privacy program.

Treating that failure mode as a data problem first, the work asked what a truly unified data model for privacy within a large organization would look like if interoperability across common process domains were forced. The methodology involved reconciliation of approximately 50 authoritative taxonomies against the W3C DPV into an implementable reference data model, subsequently evaluated through 100 machine-validated test cases.

While the artifacts prove to solve many lesser problems, four conclusions go beyond these lesser problems.

1. The DPV is not a schema, and the data structures required to operate a privacy program for a large organization with multi-jurisdictional compliance imperatives exceed the DPV’s surface by an order of magnitude.
2. The shared entities and relationships across regulations are smaller than any one regulation implies, which makes the data architecture of a regulation-agnostic core and the associated overlays an ideal approach for organizations holding two or more regulatory obligations. This value seemingly increases proportionately with the number of regulatory obligations an organization incurs.
3. The importance of identifying and reserving decisions as a function of risk. Further, the notion that decisions that

go unrecognized through latent implementation of defaults carry risk implicitly. The approximately forty implementation decisions in the model have no singular correct answer, and each should be resolved by every implementing organization, whether the implementer recognizes these as choices to be made with their own advantages and drawbacks.

4. Target process maturity, while imperfect, is a valid way to express risk tolerance through logically related process groupings (subdomains). Maturity parameterization as a technique enables visibility into the process and data rework points that are required for maturity advancement. Understanding these rework points, dependencies, and decisions further allows for shifting of their corresponding expenses from largely “discovered after the fact” to planned, and the concentration of the cost cliff between L3 and L4 is also now known in advance rather than after a program has stalled.

Lastly, I believe there is a lesson here on approach. Ontologies, taxonomies, and reference schemas exist for thousands of data applications. Further, standards of any type imply entities and relationships where one may not exist. Each of these creates a mechanism to take a data-driven approach to problem solving and process maturity issues for that space. There is real value in an approach that ideates on what the data would look like if the problem no longer existed and working backward from that, where getting better is a function of getting more precise, which is tactically applied through forced data normalization.

■ ACKNOWLEDGMENTS

GitHub Repository

Visit the repository to access the source code, track ongoing development, report issues, and stay up to date with the latest changes.

 <https://github.com/bricedobson/Privacy-Taxonomy>

Thanks

The author would like to thank the following individuals and groups for their influence on this work.

- Dr. Brenden Kuerbis and Mr. Emad AbuKhoua for their continued review of this content throughout the course it was a product of.
- The W3C Data Privacy Vocabularies and Controls Community Group for their contributions.
- Michael Ernst of the University of Washington, for his published advice on [writing technical papers](#) and [giving technical presentations](#).
- This document was compiled using [Rho-class](#), a $\text{\LaTeX}$ template developed by Guillermo Jimenez.

AI Use Disclosures

Generative AI was used in the completion of this work in the following ways.

- Proofreading and associated editing for style, clarity, and brevity within this report.
- Conversion of source metadata to BibTeX format.
- Formatting support with $\text{\LaTeX}$ and BibTeX
- Transformation of raw analysis files to a properly formatted RDF OWL Hybrid Ontology file and associated debugging.
- Transforming the analysis schema to a format compatible with the web-based explorer.
- Various code implementations and improvements within the web-based explorer application.

7. APPENDICES

Appendix A: Full Listing of Input Taxonomies by Author Type Classification

Independent Standards

International Organization for Standardization and International Electrotechnical Commission, “ISO/IEC 27701:2019 — extension to ISO/IEC 27001 technical for privacy information management — requirements and guidelines”, ISO/IEC, Geneva, Switzerland, International Standard ISO/IEC 27701:2019, Aug. 2019. [Online]. Available: <https://www.iso.org/standard/71670.html>.

H. J. Pandit *et al.*, *Data privacy vocabulary (DPV) — version 2.3: Personal data (PD) module*, W3C Community Group Report, Data Privacy Vocabularies and Controls Community Group (DPVCG), 2026. [Online]. Available: <https://w3id.org/dpv/pd>.

International Organization for Standardization and International Electrotechnical Commission, “ISO/IEC 27002:2022 — information security, cybersecurity and privacy protection — information security controls”, ISO/IEC, Geneva, Switzerland, International Standard ISO/IEC 27002:2022, Feb. 2022. [Online]. Available: <https://www.iso.org/standard/75652.html>.

International Organization for Standardization and International Electrotechnical Commission, “ISO/IEC 29100:2011 — information technology — security techniques — privacy framework”, ISO/IEC, Geneva, Switzerland, International Standard ISO/IEC 29100:2011, 2011. [Online]. Available: <https://www.iso.org/standard/45123.html>.

International Organization for Standardization, “ISO 15489-1:2016 — information and documentation — records management — part 1: Concepts and principles”, ISO, Geneva, Switzerland, International Standard ISO 15489-1:2016, 2016. [Online]. Available: <https://www.iso.org/standard/62542.html>.

International Organization for Standardization and International Electrotechnical Commission, “ISO/IEC 19944-1:2020 — cloud computing and distributed platforms — data flow, data categories and data use — part 1: Fundamentals”, ISO/IEC, Geneva, Switzerland, International Standard ISO/IEC 19944-1:2020, 2020. [Online]. Available: <https://www.iso.org/standard/79573.html>.

International Organization for Standardization and International Electrotechnical Commission, “ISO/IEC 19944-2:2022 — cloud computing and distributed platforms — data flow, data categories and data use — part 2: Guidance on application and extensibility”, ISO/IEC, Geneva, Switzerland, International Standard ISO/IEC 19944-2:2022, 2022. [Online]. Available: <https://www.iso.org/standard/79574.html>.

International Organization for Standardization and International Electrotechnical Commission, “ISO/IEC TS 27560:2023 — privacy technologies — consent record information structure”, ISO/IEC, Geneva, Switzerland, Technical Specification ISO/IEC TS 27560:2023, Aug. 2023. [Online]. Available: <https://www.iso.org/standard/80392.html>.

International Organization for Standardization and International Electrotechnical Commission, “ISO/IEC 29184:2020 — information technology — online privacy notices and consent”, ISO/IEC, Geneva, Switzerland, International Standard ISO/IEC 29184:2020, Jun. 2020. [Online]. Available: <https://www.iso.org/standard/70331.html>.

Kantara Initiative Consent and Information Sharing Work Group, *Consent receipt specification, version 1.1.0*, Kantara Initiative Technical Specification Recommendation (KI-CR-v1.1.0), Feb. 2018. [Online]. Available: <https://kantara.atlassian.net/wiki/spaces/archive/pages/3508790/Consent+Receipt+Specification>.

IEEE, “IEEE 7012-2025 — IEEE standard for machine readable personal privacy terms (MyTerms)”, Institute of Electrical and Electronics Engineers, IEEE Standard IEEE Std 7012-2025, 2025. [Online]. Available: <https://standards.ieee.org/ieee/7012/7192/>.

W3C Privacy Working Group, *Global privacy control (GPC)*, W3C Working Draft, 2025. [Online]. Available: <https://www.w3.org/TR/gpc/>.

International Organization for Standardization and International Electrotechnical Commission, “ISO/IEC 27005:2022 — information security, cybersecurity and privacy protection — guidance on managing information security risks”, ISO/IEC, Geneva, Switzerland, International Standard ISO/IEC 27005:2022, Oct. 2022. [Online]. Available: <https://www.iso.org/standard/80585.html>.

International Organization for Standardization, “ISO 31000:2018 — risk management — guidelines”, ISO, Geneva, Switzerland, International Standard ISO 31000:2018, 2018. [Online]. Available: <https://www.iso.org/standard/65694.html>.

OWASP Foundation, *OWASP top 10 privacy risks*, OWASP Top 10 Privacy Risks Project, version 2.0, 2021. [Online]. Available: <https://owasp.org/www-project-top-10-privacy-risks/>.

Governmental

European Parliament and Council of the European Union, *Regulation (eu) 2016/679 (general data protection regulation, gdpr)*, OJ L 119, 4.5.2016, pp. 1–88, 2016. [Online]. Available: <http://data.europa.eu/eli/reg/2016/679/oj>.

National Institute of Standards and Technology, *Open security controls assessment language (OSCAL)*, NIST-led machine-readable models: Catalog, Profile, System Security Plan, Component Definition, Assessment Plan, Assessment Results, Plan of Action and Milestones; plus the Profile Resolution algorithm, 2021. [Online]. Available: <https://pages.nist.gov/OSCAL/>.

National Institute of Standards and Technology, “NIST privacy framework 1.1 (initial public draft)”, National Institute of Standards and Technology, Gaithersburg, MD, NIST Cybersecurity White Paper CSWP 40 ipd, Apr. 2025. DOI: 10.6028/NIST.CSWP.40.ipd. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.40.ipd.pdf>.

Commission Nationale de l’Informatique et des Libertés (CNIL), *Record of processing activities — template (record base model)*, CNIL GDPR toolkit, OpenDocument Spreadsheet (.ods), 2019. [Online]. Available: <https://www.cnil.fr/en/gdpr-toolkit/record-processing-activities>.

State of California, *California consumer privacy act of 2018, as amended by the california privacy rights act (CCPA/CPRA)*, California Civil Code, Division 3, Part 4, Title 1.81.5, §§1798.100–1798.199.100, 2018. [Online]. Available: https://cippa.ca.gov/regulations/pdf/ccpa_statute.pdf.

Article 29 Data Protection Working Party, “Opinion 03/2013 on purpose limitation”, Article 29 Data Protection Working Party, Working Party document WP 203 (00569/13/EN), Apr. 2013. [Online]. Available: https://ec.europa.eu/justice/article-29/documentation/opinion-recommendation/files/2013/wp203_en.pdf.

Standing Committee of the National People’s Congress, *Personal information protection law of the people’s republic of china (PIPL)*, Adopted at the 30th meeting of the Standing Committee of the 13th NPC, 2021. [Online]. Available: http://www.npc.gov.cn/npc/c2/c30834/202108/t20210820_313088.html.

Federative Republic of Brazil, *Lei geral de proteção de dados pessoais (LGPD), lei nº 13.709, de 14 de agosto de 2018*, Diário Oficial da União, Brazil, 2018. [Online]. Available: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/113709.htm.

European Parliament and Council of the European Union, *Regulation (eu) 2022/2554 (digital operational resilience act, dora) — article 28(3)*, OJ L 333, 27.12.2022, pp. 1–79, 2022. [Online]. Available: <http://data.europa.eu/eli/reg/2022/2554/oj>.

European Parliament and Council of the European Union, *Directive 2002/58/ec (eprivacy directive)*, OJ L 201, 31.7.2002, pp. 37–47, 2002. [Online]. Available: <http://data.europa.eu/eli/dir/2002/58/oj>.

European Parliament and Council of the European Union, *Regulation (eu) 2022/868 (data governance act, dga)*, OJ L 152, 3.6.2022, pp. 1–44, 2022. [Online]. Available: <http://data.europa.eu/eli/reg/2022/868/oj>.

European Data Protection Board, “2025 coordinated enforcement action — implementation of the right to erasure by controllers”, European Data Protection Board, Coordinated Enforcement Framework (CEF) report, Feb. 2026. [Online]. Available: https://www.edpb.europa.eu/system/files/2026-02/edpb_cef-report_2025_right-to-erasure_en.pdf.

Article 29 Data Protection Working Party, “Guidelines on transparency under regulation 2016/679”, Article 29 Data Protection Working Party, Working Party document WP 260 rev.01, Apr. 2018. [Online]. Available: <https://ec.europa.eu/newsroom/article29/items/622227>.

S. Brooks, M. Garcia, N. Lefkowitz, S. Lightman, and E. Nadeau, “An introduction to privacy engineering and risk management in federal systems”, National Institute of Standards and Technology, Gaithersburg, MD, NIST Internal Report (NISTIR) 8062, Jan. 2017. DOI: 10.6028/NIST.IR.8062. [Online]. Available: <https://csrc.nist.gov/pubs/ir/8062/final>.

National Institute of Standards and Technology, *Privacy risk assessment methodology (PRAM)*, NIST Privacy Engineering Program (set of worksheets and catalog of problematic data actions), 2020. [Online]. Available: <https://www.nist.gov/itl/applied-cybersecurity/privacy-engineering/collaboration-space/privacy-risk-assessment/tools>.

Commission Nationale de l’Informatique et des Libertés (CNIL), *Privacy impact assessment (PIA) — methodology, templates, and knowledge bases (guides 1–3)*, CNIL PIA guides, February 2018 edition, 2018. [Online]. Available: <https://www.cnil.fr/en/privacy-impact-assessment-pia>.

Commission Nationale de l'Informatique et des Libertés (CNIL), *Open-source PIA software tool*, CNIL, free/open-source software (latest major version 3.x), 2021. [Online]. Available: <https://www.cnil.fr/en/open-source-pia-software-helps-carry-out-data-protection-impact-assessment>.

Information Commissioner's Office (ICO), *Data protection impact assessments (DPIA) — guidance and template*, ICO, Guide to the UK GDPR (Accountability and governance), 2023. [Online]. Available: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/accountability-and-governance/data-protection-impact-assessments-dpias/>.

European Union Agency for Cybersecurity (ENISA), “ENISA threat taxonomy: A tool for structuring threat information”, European Union Agency for Cybersecurity (ENISA), Tech. Rep., 2016. [Online]. Available: <https://www.enisa.europa.eu/topics/cyber-threats/threats-and-trends>.

European Union Agency for Cybersecurity (ENISA), “Technical implementation guidance on cybersecurity risk management measures (NIS2)”, European Union Agency for Cybersecurity (ENISA), Technical guidance, version 1.0, Jun. 2025. [Online]. Available: <https://www.enisa.europa.eu/publications/nis2-technical-implementation-guidance>.

European Commission, *Commission implementing regulation (eu) 2025/302 — standard forms, templates and procedures for reporting a major ICT-related incident and notifying a significant cyber threat (DORA)*, Implementing technical standards under Regulation (EU) 2022/2554; OJ, 20.2.2025, 2025. [Online]. Available: http://data.europa.eu/eli/reg_impl/2025/302/oj.

NIS Cooperation Group, European Commission, and European Union Agency for Cybersecurity (ENISA), *Common templates for cybersecurity incident reporting under the NIS2 directive*, NIS Cooperation Group, adopted at the 39th Plenary (Cyprus), May 2026. [Online]. Available: <https://digital-strategy.ec.europa.eu/en/news/nis2-cooperation-group-adopts-common-templates-incident-reporting>.

Commercial

BigID, *BigID API Overview*, <https://developer.bigid.com/api/bigid-api/>, n.d. (visited on 06/12/2026).

DataGrail, *DataGrail API v2 Reference*, <https://docs.datagrail.io/api/v2/>, n.d. (visited on 06/12/2026).

OneTrust, *OneTrust API Reference*, <https://developer.onetrust.com/onetrust/reference>, n.d. (visited on 06/12/2026).

Securiti, *Securiti API Reference*, <https://docs.securiti.ai/api-reference/index.html>, n.d. (visited on 06/12/2026).

TrustArc, *Gateway API Developers Guide*, <https://trustarchelp.zendesk.com/hc/en-us/sections/41665598864531-Gateway-API-Developers-Guide>, n.d. (visited on 06/12/2026).

IAB Europe and IAB Tech Lab, *Transparency and consent framework (TCF) — technical specifications*, IAB Europe / IAB Tech Lab, version 2.3, 2025. [Online]. Available: <https://iabeurope.eu/transparency-consent-framework/>.

R. J. Cronk and EnterPrivacy Consulting Group, *Categories of personal information*, EnterPrivacy Consulting Group, personal-data taxonomy, 2017. [Online]. Available: <https://enterprivacy.com/>.

Academic Work

R. J. Cronk, *Strategic Privacy by Design*, Second. International Association of Privacy Professionals (IAPP), 2018, ISBN: 978-1948771009.

LINDDUN and DistriNet, KU Leuven, *LINDDUN privacy threat modeling framework (LINDDUN GO and LINDDUN Pro)*, KU Leuven (DistriNet), 2024. [Online]. Available: <https://linddun.org/>.

P. Ryan, R. Brennan, and H. J. Pandit, “DPCat: Specification for an interoperable and machine-readable data processing catalogue based on GDPR”, *Information*, vol. 13, no. 5, p. 244, 2022. DOI: 10.3390/info13050244. [Online]. Available: <https://doi.org/10.3390/info13050244>.

S. Human, M. Schrems, A. Toner, Gerben, and B. Wagner, *Advanced data protection control (ADPC)*, Draft specification, noyb — European Center for Digital Rights and Sustainable Computing Lab (WU Wien), 2021. [Online]. Available: <https://www.dataprotectioncontrol.org/spec/>.

Appendix B: Mapping of Taxonomies to Domains

Table 8. Input taxonomies mapped to the twelve capability-area subdomains of the reference model, based on the DPV.

Capability-area domain	Input taxonomies
#1 Processing Inventory	[4, 5, 8, 20, 22–24, 28–33]
#2 Purpose Specification & Governance	[4, 8, 22, 24, 33–38]
#3 Personal Data Inventory & Classification	[4, 8, 20, 22, 23, 26, 28, 30, 33, 35, 36, 38–40]
#4 Legal Basis Management	[4, 5, 8, 22, 24, 33, 38, 40]
#5 Entities, Roles & Accountability	[4, 5, 8, 22, 24, 28, 33, 38, 40, 41]
#6 Consent Management	[4, 8, 21, 22, 24, 33, 37, 42–49]
#7 Data Subject Rights Management	[4, 8, 21–24, 33, 38, 40, 50]
#8 Notice & Transparency	[4, 8, 22, 24, 33, 43, 45–48, 51]
#9 Risk & Impact Assessment (DPI-A/PIA)	[4, 8, 22, 24, 27, 30, 52–60]
#10 Technical & Organizational Measures	[4, 5, 8, 18, 22, 23, 30, 59, 61]
#11 Incident & Breach Management	[4, 8, 22, 30, 41, 48, 49, 60–63]
#12 Regulatory Reporting & Disclosure	[4, 8, 18, 22, 24, 31, 32, 41, 49, 62, 63]

Appendix C: Summary Analysis Statistics

Table 9. Reference Data Model Characteristics

Subdomain	Entities	Relationships	Cross-Domain	Decisions	Rework Points
1 – Processing Inventory	2	20	17	7	3
2 – Purpose Specification & Governance	2	5	6	3	1
3 – Personal Data Inventory & Classification	7	14	7	6	3
4 – Legal Basis Management	5	8	16	2	5
5 – Entities, Roles, & Accountability	12	30	23	6	6
6 – Consent Management	4	10	9	5	3
7 – Data Subject Rights Management	5	9	5	6	3
8 – Notice & Transparency	5	4	6	2	6
9 – Risk & Impact Assessment	3	8	12	4	9
10 – Control Measures	4	9	7	4	6
11 – Incident & Breach Management	5	9	10	2	3
12 – Regulatory Reporting & Disclosure	5	3	5	2	2

Table 10. Reference Data Model Rework Distribution

Subdomain	$L_1 \rightarrow L_2$	$L_2 \rightarrow L_3$	$L_3 \rightarrow L_4$	$L_4 \rightarrow L_5$	Totals
1 – Processing Inventory	1	1	3	1	6
2 – Purpose Specification & Governance	1	1	1	1	4
3 – Personal Data Inventory & Classification	1	1	3	1	6
4 – Legal Basis Management	1	1	5	1	8
5 – Entities, Roles, & Accountability	1	1	6	1	9
6 – Consent Management	1	1	3	1	6
7 – Data Subject Rights Management	1	1	3	1	6
8 – Notice & Transparency	1	1	4	1	7
9 – Risk & Impact Assessment	1	2	6	1	10
10 – Control Measures	1	1	5	1	8
11 – Incident & Breach Management	1	1	3	1	6
12 – Regulatory Reporting & Disclosure	1	1	2	1	5
Totals	13	14	44	13	84

Table 11. Reference Data Model Dependency Map by Subdomain

Subdomain	D1	D2	D3	D4	D5	D6	D7	D8	D9	D10	D11	D12	Total (Out)
1 – Processing Inventory	1		1	2	2								6
2 – Purpose Specification & Governance	1	1		2					1				5
3 – Personal Data Inventory & Classification			1										1
4 – Legal Basis Management				1	2				1				4
5 – Entities, Roles, & Accountability					1								1
6 – Consent Management			1				1	1					3
7 – Data Subject Rights Management			1				1	1					3
8 – Notice & Transparency													0
9 – Risk & Impact Assessment					1				1		1		3
10 – Control Measures										1			1
11 – Incident & Breach Management	1								1		1	1	4
12 – Regulatory Reporting & Disclosure	1		1	1	1							1	5
Total (In)	4	2	4	6	7	2	1	1	4	1	2	2	36

Appendix D: Risk-Discretionary Implementation Decisions

Table 12. The risk-discretionary implementation decisions.

ID	Decision
01	What a single row in the processing inventory actually represents.
02	How finely processing activities are split into separate records.
03	Whether a processing activity can contain other processing activities.
04	Whether a rights request is a request with a status or a record of the work done to fulfill it.
05	Whether consent is a record that changes over time or a stream of events that never changes.
06	What level of detail consent is captured against.
07	Which consent-record format does the organization adopt as its canonical form.
08	Whether risk is one entity with attributes or a graph of related concepts.
09	What the organization's risk taxonomy is fundamentally organized around.
10	How precisely is risk scored, and on what kind of scale.
11	How the different assessment types relate to one another structurally.
12	Whether control themes are a class hierarchy or an attribute on a single control class.
13	What shape the control catalogue takes.
14	How the privacy control set relates to the wider information security control set.
15	Whether control applicability is scoped by the party role the organization holds.
16	Whether the personal data taxonomy is imported or maintained internally.
17	How many dimensions are used to express the sensitivity of personal data.
18	How many layers of detail the data inventory carries beneath the category level.
19	Whether sensitivity is a fixed property of the data or varies with the context of use.
20	How deep the sub-processor chain is represented before it stops being modelled.
21	Whether data subjects appear as categories, as identified individuals, or as both.
22	Whether recipients of personal data are recorded as categories, by name, or both.
23	Whether personal data is tracked as a type, as a specific instance, or as both linked together.
24	At what point does a relationship stop being an edge and become an entity.
25	Whether notices are owned by a single domain or by whichever domain triggers them.
26	How a layered privacy notice is structured across its levels of detail.
27	Whether the processing inventory and the data map are one structure or two.
28	How narrowly regulatory reporting templates are scoped.
29	How an assessment of compatible further use is recorded and where the outcome lives.
30	Whether anonymizing personal data counts as fulfilling an erasure request.
31	What happens to the rights response clock when the organization must verify the requester's identity.
32	Which incident lifecycle model the organization follows.
33	Whether the number of affected individuals is stated as a firm figure or an estimate with a confidence range.
34	Whether near misses are recorded alongside actual incidents.
35	Whether party role labels are translated across regulatory regimes.
36	Whether corporate group structure is modeled as a first-class concern.
37	Whether the entity used to calculate regulatory fines is modeled explicitly.
38	How far across the model the vulnerable population and children flags reach.
39	Whether an AI system is a kind of technology system or a peer concept alongside it.
40	Whether aggregate statements of data use are stored directly or derived on demand.

8. REFERENCES

- [1] International Association of Privacy Professionals, *Data protection and privacy laws now in effect in 144 countries*, IAPP, Jan. 28, 2025. [Online]. Available: <https://iapp.org/news/a/data-protection-and-privacy-laws-now-in-effect-in-144-countries> (visited on 05/23/2026).
- [2] Cisco, “Cisco 2026 Data and Privacy Benchmark Study”, Cisco, Report, Jan. 26, 2026. [Online]. Available: https://www.cisco.com/c/dam/en_us/about/doing_business/trust-center/docs/cisco-privacy-benchmark-study-2026.pdf (visited on 05/23/2026).
- [3] CMS Legal, “GDPR Enforcement Tracker Report 2025: Numbers and Figures”, CMS Legal, Report, May 13, 2025. [Online]. Available: <https://cms.law/en/int/publication/gdpr-enforcement-tracker-report> (visited on 05/23/2026).
- [4] European Parliament and Council of the European Union, *Regulation (eu) 2016/679 (general data protection regulation, gdpr)*, OJ L 119, 4.5.2016, pp. 1–88, 2016. [Online]. Available: <http://data.europa.eu/eli/reg/2016/679/oj>.
- [5] International Organization for Standardization and International Electrotechnical Commission, “ISO/IEC 27701:2019 — extension to ISO/IEC 27001 technical for privacy information management — requirements and guidelines”, ISO/IEC, Geneva, Switzerland, International Standard ISO/IEC 27701:2019, Aug. 2019. [Online]. Available: <https://www.iso.org/standard/71670.html>.
- [6] United Nations Conference on Trade and Development, “World Investment Report — the top 100 multinational enterprises”, UNCTAD, Report, 2024. [Online]. Available: <https://unctad.org/publications-search?f%5B0%5D=product%3A397>.
- [7] International Association of Privacy Professionals, “Privacy Governance Report 2024”, International Association of Privacy Professionals, Report, 2024. [Online]. Available: <https://iapp.org/resources/article/privacy-governance-report> (visited on 05/23/2026).
- [8] H. J. Pandit *et al.*, *Data privacy vocabulary (DPV) — version 2.3: Personal data (PD) module*, W3C Community Group Report, Data Privacy Vocabularies and Controls Community Group (DPVCG), 2026. [Online]. Available: <https://w3id.org/dpv/pd>.
- [9] CMMI Institute, *CMMI institute*, ISACA. [Online]. Available: <https://cmmiinstitute.com/> (visited on 08/01/2026).
- [10] NIST Privacy Workforce Public Working Group, “NIST privacy workforce taxonomy”, National Institute of Standards and Technology, Gaithersburg, MD, NIST Cybersecurity White Paper (CSWP) 38 ipd, Nov. 2024. DOI: 10.6028/NIST.CSWP.38.ipd. [Online]. Available: <https://www.nist.gov/privacy-framework/workforce-advancement/privacy-workforce-taxonomy>.
- [11] R. Densmore, Ed., *Privacy Program Management: Tools for Managing Privacy Within Your Organization*, Third. Portsmouth, NH: International Association of Privacy Professionals (IAPP), 2022.
- [12] S. Harris and A. Seaborne, *SPARQL 1.1 query language*, W3C Recommendation, World Wide Web Consortium, Mar. 2013. [Online]. Available: <https://www.w3.org/TR/sparql11-query/> (visited on 05/30/2026).
- [13] S. Staab and R. Studer, Eds., *Handbook on Ontologies* (International Handbooks on Information Systems), 2nd ed. Berlin, Heidelberg: Springer Berlin Heidelberg, 2009, Retrieved via Georgia Tech Library, ISBN: 978-3-540-92673-3. DOI: 10.1007/978-3-540-92673-3. [Online]. Available: <https://doi.org/10.1007/978-3-540-92673-3> (visited on 06/14/2026).
- [14] RDFLib Team, *RDFLib: A Python library for working with RDF*, Software. [Online]. Available: <https://github.com/RDFLib/rdfliib> (visited on 05/30/2026).
- [15] U.S. Department of Health, Education, and Welfare, “Records, computers and the rights of citizens: Report of the secretary’s advisory committee on automated personal data systems”, U.S. Department of Health, Education, and Welfare, Washington, DC, Report DHEW Publication No. (OS) 73-94, 1973. [Online]. Available: <https://aspe.hhs.gov/reports/records-computers-rights-citizens> (visited on 06/30/2026).
- [16] Organisation for Economic Co-operation and Development, *Recommendation of the council concerning guidelines governing the protection of privacy and transborder flows of personal data*, OECD Legal Instrument OECD/LEGAL/0188, 1980. [Online]. Available: <https://legalinstruments.oecd.org/en/instruments/OECD-LEGAL-0188> (visited on 06/05/2026).
- [17] International Organization for Standardization and International Electrotechnical Commission, “ISO/IEC 27002:2022 — information security, cybersecurity and privacy protection — information security controls”, ISO/IEC, Geneva, Switzerland, International Standard ISO/IEC 27002:2022, Feb. 2022. [Online]. Available: <https://www.iso.org/standard/75652.html>.
- [18] National Institute of Standards and Technology, *Open security controls assessment language (OSCAL)*, NIST-led machine-readable models: Catalog, Profile, System Security Plan, Component Definition, Assessment Plan, Assessment Results, Plan of Action and Milestones; plus the Profile Resolution algorithm, 2021. [Online]. Available: <https://pages.nist.gov/OSCAL/>.
- [19] SCAMPI Upgrade Team, “Appraisal requirements for CMMI version 1.3 (ARC, v1.3)”, Software Engineering Institute, Carnegie Mellon University, Tech. Rep. CMU/SEI-2011-TR-006, Apr. 2011. DOI: 10.1184/R1/6571994.v1. [Online]. Available: <https://doi.org/10.1184/R1/6571994.v1> (visited on 08/01/2026).

- [20] BigID, *BigID API Overview*, <https://developer.bigid.com/api/bigid-api/>, n.d. (visited on 06/12/2026).
- [21] DataGrail, *DataGrail API v2 Reference*, <https://docs.datagrail.io/api/v2/>, n.d. (visited on 06/12/2026).
- [22] OneTrust, *OneTrust API Reference*, <https://developer.onetrust.com/onetrust/reference>, n.d. (visited on 06/12/2026).
- [23] Securiti, *Securiti API Reference*, <https://docs.securiti.ai/api-reference/index.html>, n.d. (visited on 06/12/2026).
- [24] TrustArc, *Gateway API Developers Guide*, <https://trustarchelp.zendesk.com/hc/en-us/sections/41665598864531-Gateway-API-Developers-Guide>, n.d. (visited on 06/12/2026).
- [25] A. Cavoukian, “Privacy by design: The 7 foundational principles — implementation and mapping of fair information practices”, Information and Privacy Commissioner of Ontario, Toronto, Ontario, Canada, Report, 2011. [Online]. Available: <https://www.ipc.on.ca/en/media/1826/download?attachment> (visited on 07/15/2026).
- [26] R. J. Cronk, *Strategic Privacy by Design*, Second. International Association of Privacy Professionals (IAPP), 2018, ISBN: 978-1948771009.
- [27] LINDDUN and DistriNet, KU Leuven, *LINDDUN privacy threat modeling framework (LINDDUN GO and LINDDUN Pro)*, KU Leuven (DistriNet), 2024. [Online]. Available: <https://linddun.org/>.